



Vanguard Penetration Test

Windows Privilege Escalation - Portfolio Sample

Prepared by Lenny Bos
Cyber Security student and software developer

Educational context
This report was created for a penetration-testing assignment in a controlled lab. All organisations, systems, credentials, and vulnerabilities described here are fictional or lab-based. This portfolio edition excludes operational credentials, proof-of-concept payloads, command transcripts, and raw screenshots.

5	1	4
Validated findings	Critical finding	High findings

Assessment type	Grey box - insider threat scenario
Environment	Isolated Windows Active Directory lab
Assessment period	15 May 2026 - 1 June 2026
Document purpose	Public portfolio sample

Executive summary

The assessment examined whether a standard domain user could abuse Windows configuration weaknesses to obtain local administrator or SYSTEM-level privileges. Testing was limited to an isolated educational environment and stopped after each issue was safely validated.

Five privilege-escalation paths were confirmed. The most serious issue was an installer-policy misconfiguration that could allow a standard user to execute an installer with elevated privileges. Four additional high-risk findings affected Windows services, executable permissions, and the system PATH.

Assessment outcome

Result	What it means
Privilege escalation was possible	Multiple independent misconfigurations could elevate a standard user to local administrator or SYSTEM.
Risk was concentrated	All validated findings were rated High or Critical, making remediation a priority.
Controls were actionable	Each path could be reduced through policy changes, permission hardening, and configuration monitoring.

Priority actions

- Disable the elevated-installer policy at both machine and user scope.
- Quote service paths and remove standard-user write access from service directories and binaries.
- Restrict service-management permissions to authorised administrator accounts.
- Remove writable directories from the system PATH and monitor future configuration drift.
- Repeat Windows hardening reviews and alert on privilege-escalation indicators.

Scope and methodology

The scenario modelled an insider with a valid standard domain account and limited prior knowledge. No production systems, external networks, or real organisational data were used.

IN SCOPE	OUT OF SCOPE
Windows 11 client Administrative workstation Local services and policies Standard domain-user context	Production infrastructure External networks Real credentials or personal data Persistence or data exfiltration

Assessment workflow

1	2	3	4
Enumerate	Validate	Assess	Report
Review services, permissions, policies, and common escalation paths.	Confirm each issue safely without persistence or real data access.	Evaluate likelihood, impact, and confidentiality-integrity-availability effects.	Translate evidence into prioritised and practical remediation.

Frameworks and tools

The work was structured using PTES concepts and mapped to MITRE ATT&CK; techniques. Risk decisions were informed by likelihood, technical impact, and confidentiality-integrity-availability considerations. The lab workflow used PowerShell, PrivescCheck, Sysinternals, winPEAS, Windows Event Viewer, WiX Toolset, and VirtualBox.

Findings overview

The table below summarises the validated issues without exposing payloads, credentials, raw commands, or sensitive screenshots.

ID	Finding	Risk	Impact	Primary remediation
B-01	Unquoted service path	High	A writable path segment could be used to influence service execution.	Quote the full path and harden every parent directory ACL.
B-02	Elevated installer policy	Critical	A standard user could execute installer content with SYSTEM privileges.	Disable the policy at machine and user scope; control installer execution.
B-03	Insecure service-file permissions	High	A service binary could be replaced before execution by a privileged service.	Limit write access to Administrators and SYSTEM; review service ACLs.
B-04	Weak service permissions	High	A standard user could modify or control a privileged Windows service.	Restrict service-control and configuration rights to authorised admins.
B-05	Writable system PATH directory	High	A vulnerable process could load attacker-controlled code from a PATH directory.	Remove writable PATH entries and harden directory permissions.

Risk interpretation: All findings required local access, but each created a credible path from a standard account to elevated control of the host. The elevated-installer policy was prioritised because exploitation was direct and SYSTEM-level.

Selected finding details

B-02 Elevated installer policy		CRITICAL
Description	Installer policy settings were enabled at both machine and user scope, allowing elevated installation in a standard-user context.	
Business impact	Arbitrary installer content could run with SYSTEM privileges, affecting confidentiality, integrity, and availability.	
Remediation	Disable the policy through Group Policy at both scopes. Add application control such as AppLocker or WDAC where appropriate and alert on unexpected installer activity.	
MITRE mapping	T1548.002 - Abuse Elevation Control Mechanism: Bypass User Account Control	

B-03 Insecure service-file permissions		HIGH
Description	A service executable running as LocalSystem was writable by standard users.	
Business impact	Replacing the executable could cause attacker-controlled code to run when the privileged service starts.	
Remediation	Restrict write access to Administrators and SYSTEM. Review service directories and binaries regularly for permission drift.	
MITRE mapping	T1574.010 - Hijack Execution Flow: Services File Permissions Weakness	

Remediation roadmap

The highest-value actions remove direct escalation paths first, then reduce the chance that similar weaknesses return.

Priority	Action	Expected result
1 - Immediate	Disable elevated installer policy and review current installer controls.	Removes the critical SYSTEM-level installation path.
2 - Immediate	Quote vulnerable service paths and correct service-file, folder, and service-control ACLs.	Blocks the confirmed service-based escalation paths.
3 - Short term	Remove user-writable locations from the system PATH and validate search-order behaviour.	Reduces executable and DLL search-order hijacking risk.
4 - Ongoing	Monitor privileged-group membership, service changes, installer events, and permission drift.	Improves detection and prevents silent reintroduction of weaknesses.

Skills demonstrated

Technical	Professional
Windows privilege-escalation analysis Service and NTFS permission review Installer-policy assessment PowerShell-based validation MITRE ATT&CK; mapping	Scoping and ethical test boundaries Risk prioritisation Executive and technical reporting Evidence-based remediation Clear communication of limitations

Portfolio note

This edition intentionally focuses on methodology, risk, and remediation. Exploit payloads, usernames, command transcripts, internal paths, and raw evidence have been removed because they do not add value for a public portfolio audience.